Plan Offero — Parte 9 de 10

Calidad, pruebas y seguridad · Decisiones de producto pendientes · Riesgos y plan B · Versión del 29 de octubre de 2026

15. Calidad, pruebas y seguridad

15.1 Checklist de pruebas manuales por módulo

Cada prueba se hace en el Preview o en local (offero-dev) con cuentas de prueba; en producción solo se verifica sin crear datos (Parte 3, 6.6). Las pruebas de permisos se hacen con **dos cuentas de roles distintos** y, cuando aplica, cambiando ids en la URL.

Módulo	Camino feliz	Casos de error	Permisos por rol
M0	La URL abre la portada en escritorio y celular; un PR genera Preview	Import con mayúsculas distintas → el build falla en Vercel (revisar el log)	—
M1	Registro como cliente y como proveedor; inicio y cierre de sesión; editar nombre	Correo repetido; contraseña incorrecta; campos vacíos	Petición con rol admin queda client · nadie cambia su propio rol · sin sesión, las rutas protegidas van a /login · botón Atrás tras cerrar sesión
M2	Crear y editar negocio; listado; filtro por categoría; detalle	Campos inválidos; segundo negocio del mismo proveedor; id inexistente → 404	Cliente no crea negocios · proveedor A no edita el de B · oculto no aparece al público
M3	Publicar, listar, ver detalle, editar y cancelar	Fecha pasada; cantidad 0; categoría inexistente; editar con cotizaciones	Proveedor no crea solicitudes · cliente A no edita la de B · cancelada desaparece para proveedores
M4	Cotizar; comparar y ordenar; elegir; retirar	Segunda cotización del mismo negocio; vigencia vencida; doble clic en Elegir	Proveedor B no ve cotizaciones de otros · cliente no acepta en solicitud ajena · los tres estados cambian a la vez
M5	Enviar y ver mensajes; bandeja; leídos	Mensaje vacío o de más de 2000 caracteres	Proveedor que no cotizó no escribe · tercero no lee · remitente no edita · no se ven correos
M6	Reseñar una solicitud adjudicada; ver promedio y lista	Puntuación fuera de 1–5; comentario muy corto; segunda reseña	Sin cotización aceptada no reseña · oculta no cuenta en el promedio
M7	Categorías, usuarios, reportes, ocultar y mostrar	Borrar categoría en uso; reporte repetido	No admin no entra a /administrador ni llama operaciones de admin · dueño ve su contenido oculto

15.2 Prueba cruzada: cada módulo lo prueba alguien distinto

Módulo (autor)	Lo prueba	Cuándo
M0 (Daniel)	Iker	sáb 7 nov
M1 (Diego)	Iker: intentar volverse admin y entrar a rutas ajenas	mié 18 nov
M2 (Daniel)	Wilson	dom 6 dic
M3 (Wilson)	Daniel	dom 6 dic
M4 (Diego)	Daniel (y la función de aceptar, Iker)	dom 6 dic
M7 mínimo (Iker)	Diego	dom 6 dic

Módulo (autor)	Lo prueba	Cuándo
Núcleo completo	Daniel (QA) con una empresa del piloto	Sprint 5 (7–13 dic)
M5 (Wilson)	Iker: intentar leer y escribir en conversaciones ajenas	vie 15 ene
M6 (Iker)	Wilson	vie 15 ene
MVP completo	Los cuatro, cada uno un módulo ajeno al azar	lun 25 – mié 27 ene

Quien prueba registra cada error en la sección 10 del documento con la plantilla de bug de la Parte 10. El autor corrige; quien probó verifica la corrección.

15.3 Checklist de seguridad del MVP

Base de datos

☐ RLS activada en todas las tablas (el RLS automático lo hace; verificar en el panel que ninguna diga «RLS disabled»).

☐ Cada tabla tiene política explícita para SELECT, INSERT, UPDATE y DELETE (aunque sea «nadie»).

☐ Ninguna política abierta a todos sin razón escrita (por ejemplo, SELECT público de categorías y negocios visibles sí tiene razón).

☐ Las vistas (public_profiles, promedio de reseñas) no exponen correos ni filas ocultas; revisadas por Diego.

☐ Funciones con privilegios elevados (trigger de perfiles, aceptar cotización) validan quién llama y fijan search_path; revisadas por Iker.

☐ Restricciones CHECK y UNIQUE en estados, números y unicidades; claves foráneas sin borrado en cascada donde se pierda historial.

Claves y repositorio

☐ Ninguna clave privada en el frontend: solo la URL y la clave pública llevan `NEXT_PUBLIC_`.

☐ La clave secreta (service_role) no se usa en la app ni está en Vercel, GitHub o el chat.

☐ `.env.local` nunca se sube; `.env.example` solo tiene nombres.

☐ Revisión del historial antes de la entrega: ninguna clave en commits pasados (si aparece, se regenera en Supabase).

Rutas y servidor

☐ Cada ruta protegida verifica sesión y rol en el servidor con el patrón de Diego, no solo ocultando botones.

☐ Cada Server Action vuelve a verificar el rol y la propiedad del recurso (no confía en datos del formulario como client_id u owner_id).

☐ Validación en el servidor de todos los formularios: tipos, longitudes, fechas futuras, números positivos.

☐ Los errores al usuario no muestran detalles internos (mensajes de la base o trazas).

☐ Ningún correo de un usuario se muestra a otro; los nombres salen de public_profiles.

15.4 Checklist de publicación en Vercel (antes de marcar un módulo como Terminado)

☐ El PR fue revisado, aprobado y fusionado con merge commit; el despliegue de producción terminó en «Ready».

☐ Si el PR tenía SQL: Diego lo aplicó en offero-prod **antes** de fusionar, y el archivo está en `supabase/sql/`.

☐ Las variables de entorno nuevas (si hubo) están en Vercel en Production y Preview, y se volvió a desplegar.

☐ Verificación de humo en producción con tu cuenta real: la página abre, sin errores en la consola, y el camino feliz se puede recorrer sin crear datos inventados.

☐ Probado en el celular (vista adaptable).

☐ Las operaciones principales funcionan con datos reales de una empresa del piloto (regla del documento).

☐ La prueba cruzada está hecha y sus errores corregidos o registrados.

☐ Sección 8 del documento: el módulo dice Terminado y Publicado: Sí; secciones 9 y 10 al día.

16. Decisiones de producto pendientes

Lidera cada decisión Diego (PO), salvo que se indique otra cosa. Se registran en la sección 11 del documento (plantilla en la Parte 10).

Decisión	Por qué importa	Opciones	Cómo validarla barato	Lidera · decidir antes de
Mercado inicial	Con «todo tipo de producto» en Bogotá no hay suficientes proveedores en cada categoría: una solicitud sin cotizaciones mata la confianza (arranque en frío)	a) Todas las categorías · b) 1–3 categorías del piloto (las de las empresas que ya tienen) · c) Por tipo de pedido (al por mayor, personalizado)	Las entrevistas: qué compran y venden las empresas del piloto. Mirar en qué categoría hay al menos 2 proveedores dispuestos a cotizar	Diego · lista inicial lun 9 nov (para categories); decisión final dom 22 nov
Enfoque B2B	Cambia el lenguaje, los campos que importan (cantidades, condiciones, factura) y a quién se busca en el piloto	a) B2B: empresas que compran a empresas · b) B2C: personas que compran a negocios · c) Ambos, con el mismo flujo	Preguntar en las entrevistas quién compra, cuánto y con qué frecuencia. Contar cuántas solicitudes reales del piloto son de empresas	Diego · dom 29 nov
Monetización	No se implementa (pagos fuera del MVP), pero el profesor y la presentación van a preguntar cómo se sostendría	a) Suscripción mensual para proveedores · b) Cobro por cotización enviada o por cliente conseguido · c) Proveedores destacados · d) Comisión por transacción (requiere pagos; después del MVP)	Preguntar a los proveedores cuánto pagan hoy por conseguir clientes y si pagarían por solicitudes calificadas. Sin cobrar nada	Diego · vie 15 ene (para la presentación)
Reglas contra reseñas falsas	Si cualquiera puede reseñar, se pierde la confianza (hipótesis H4) y un competidor puede hundir a otro	a) Solo el cliente de una cotización aceptada, una por solicitud (propuesta actual) · b) Además, que el cliente marque «trabajo completado» · c) Además, reportes y ocultar desde el admin (M7)	Preguntar a compradores en qué reseñas confían. Revisar los reportes que lleguen en diciembre	Iker con Diego · dom 6 dic (antes de crear reviews)
Correos de confirmación (D-09)	El correo incluido en Supabase no llega a usuarios reales	a) Desactivar «Confirm email» en el MVP · b) SMTP propio (agrega un proveedor externo: restricción 1)	Probar el registro de una empresa del piloto en producción	Diego · vie 30 oct

16.1 Guion para entrevistar a 5 posibles usuarios

- **A quién** [SUPUESTO]: 3 compradores y 2 proveedores, empezando por las empresas que ya tienen y pidiéndoles referidos.
- **Quién y cómo:** Diego dirige; Daniel toma notas. 20–30 minutos, en persona o por videollamada. Entre el lun 9 y el dom 29 nov.
- **Reglas:** preguntar por el pasado real («la última vez que...»), no por hipótesis («¿usaría...?»); no mostrar la app hasta el final; no defender la idea; anotar frases textuales.
- **Registro:** notas en `docs/entrevistas/` (una por persona, sin datos sensibles) y un resumen de conclusiones por hipótesis (Parte 2, 5.2).

Bloque	Compradores	Proveedores
Apertura (2 min)	Agradecer; explicar que es un proyecto universitario, que no se vende nada y que se toman notas (pedir permiso)	Igual
Contexto (5 min)	¿Qué compra tu negocio con más frecuencia a otros proveedores? ¿Productos estándar, personalizados o al por mayor?	¿Qué vendes y a quién? ¿Cómo te llegan los clientes nuevos hoy?
Última vez (8 min)	Cuéntame la última vez que tuviste que conseguir un proveedor nuevo. ¿Cómo lo buscaste? ¿Cuánto tardaste? ¿A cuántos les pediste precio?	Cuéntame la última vez que te pidieron una cotización. ¿Por qué canal? ¿Cuánto tardaste en responder? ¿La ganaste?
Dolor (5 min)	¿Qué fue lo más difícil o frustrante? ¿Cómo comparaste las propuestas? ¿Cómo decidiste en quién confiar?	¿Qué te hace perder tiempo con las cotizaciones? ¿Cuántas cotizas que no se concretan?
Confianza y dinero (4 min)	¿Te fías de reseñas de otros compradores? ¿Qué necesitarías ver de un proveedor que no conoces?	¿Cuánto inviertes hoy en conseguir clientes (publicidad, ferias, comisiones)? ¿Pagarías por recibir solicitudes de clientes que ya saben lo que quieren?
Cierre (3 min)	Mostrar el flujo en 1 minuto. ¿Publicarías una solicitud real en el piloto? ¿Conoces a alguien más a quien debamos entrevistar?	¿Te registrarías y cotizarías solicitudes reales en el piloto? ¿Conoces a otro proveedor?

17. Gestión de riesgos y plan B

La matriz completa está en la Parte 1 (2.3). Aquí va qué hacer cuando un riesgo se materializa.

Alguien deja el equipo o no cumple

- **Paso 1 (día 2 sin señales):** el facilitador de la Daily le escribe en privado, con tono amable: ¿estás bien?, ¿necesitas ayuda?, ¿cambiaron tus horas?
- **Paso 2 (una semana sin avance):** Diego habla con la persona y acuerdan algo concreto: menos alcance, pareja o un cambio de tareas.
- **Paso 3 (dos semanas, o si se va):** sus módulos pasan a versión mínima y se reparten entre quien tenga más margen (en orden: Daniel, Iker). Se informa al profesor con hechos, no con quejas.
- Lo que tenga a medias queda en su rama y en el tablero: por eso los PR pequeños y la documentación al día.

Un módulo se atrasa más de un sprint

- Se revisa en la Retro por qué (estimación, bloqueo técnico, horas).
- Primera medida: **pareja** con quien domina el tema (RLS → Iker, diseño → Daniel, autenticación → Diego) durante el siguiente sprint.

- Segunda: **reducir el alcance** del módulo a su versión mínima y mover lo demás al orden de recorte.
- Tercera: si está en la ruta crítica (M1, M3, M4), alguien con margen toma una parte concreta (como Iker con «Mis cotizaciones»).
- Nunca: pedir más horas semanales o trabajar de noche para recuperar.

Supabase da problemas

- **El proyecto está pausado** (plan gratuito, por inactividad [verificar]): Diego lo reactiva desde el panel; se revisa antes de cada demo y al volver de vacaciones.
- **Se alcanza un límite del plan gratuito** (correos, almacenamiento, conexiones): revisar el uso en el panel; para el MVP no debería pasar, pero si pasa, se registra y se decide como decisión pendiente (no se paga sin acuerdo).
- **Supabase está caído:** revisar su página de estado; si es general, se espera y se trabaja en la parte visual. Antes de una demo, tener capturas o un video del flujo como respaldo.
- **Un cambio de esquema rompió dev:** se corrige con un nuevo archivo SQL; nunca editando uno ya aplicado. Prod no se toca hasta que dev esté bien.

Vercel da problemas

- **«Deployment Blocked» por el autor del commit** (plan Hobby): fusionar con merge commit (Diego queda como autor); si persiste, Diego hace un commit vacío en main.
- **El build falla en Vercel pero no en local:** leer el log; casi siempre son mayúsculas en un import o una variable de entorno faltante.
- **Producción quedó rota después de un merge:** en Vercel, volver al despliegue anterior que funcionaba (opción de promover o revertir un despliegue anterior [verificar el nombre actual]); luego corregir con un PR nuevo.

Enero rinde menos de lo previsto

- El MVP v1 (vie 15 ene) es la prioridad; las versiones completas se recortan en el orden de abajo.
- Quien sepa que no estará en enero lo dice en la Planning del Sprint 6 (dom 13 dic) para reacomodar antes del descanso.

17.1 Orden exacto de recorte de alcance

Si vamos cortos de tiempo, se recorta en este orden, de arriba hacia abajo, y solo hasta donde haga falta. Cada recorte lo decide Diego y se registra en la sección 11.

#	Se recorta	Historias	Qué queda en su lugar
1	Extras de enero: logo del negocio, búsqueda por nombre, inicio con Google	OFF-020, OFF-021, OFF-060	Nada (no son necesarios)
2	Tiempo real en mensajes	OFF-040	Los mensajes se ven al recargar
3	Suspender cuentas	OFF-052	El admin oculta el contenido del usuario
4	Cambiar roles desde el panel	OFF-051	Diego cambia el rol con SQL en el panel de Supabase
5	Editar y ordenar reseñas	OFF-044	Las reseñas no se editan; lista por fecha
6	Contador de no leídos	OFF-039	La bandeja marca las conversaciones con mensajes nuevos
7	M7 mínimo se reduce a categorías y ocultar	OFF-048, OFF-049	Usuarios y reportes se revisan en el panel de Supabase
8	Bandeja y botones de mensajes	OFF-037, OFF-038	Conversación dentro del detalle de la solicitud

#	Se recorta	Historias	Qué queda en su lugar
9	Mensajería completa (M5)	OFF-035, OFF-036	Contacto directo con el teléfono o WhatsApp del negocio (ya existe en M2)
10	Promedio y lista de reseñas en el negocio	OFF-043	Reseñas visibles en el detalle de la solicitud adjudicada

Nunca se recorta: ninguna historia Must (M0 a M4, el camino feliz), la seguridad (RLS, rutas protegidas, validaciones en el servidor) ni la regla de «sin datos ficticios». Es mejor entregar el núcleo seguro y funcionando que ocho módulos a medias.